

CanTelcoX

Plateforme commerciale d'un opérateur mobile canadien

Dossier de domaine, contexte et glossaire

Phase préparatoire — fondations métier pour l'architecture

Cours LOG430 — Architecture logicielle

Préparé pour : Pierre Gauthier

Version 1.0 — Mai 2026

Table des matières

1. Introduction et objectifs du dossier	4
1.1 Comment lire ce dossier.....	4
1.2 Rappel du périmètre CanTelcoX.....	4
2. Le secteur des télécommunications mobiles au Canada.....	5
2.1 Structure du marché.....	5
2.2 Types d'opérateurs.....	5
2.3 Modèles commerciaux : prépayé vs postpayé	5
3. Cadre réglementaire canadien	7
3.1 CRTC et la Loi sur les télécommunications	7
3.2 LPRPDE et Loi 25.....	7
3.3 Autres textes et obligations.....	7
4. Fonctionnement technique d'un opérateur mobile.....	9
4.1 Vue d'ensemble de la chaîne.....	9
4.2 Du numéro de téléphone au profil d'abonné.....	9
4.3 HLR, HSS, UDM : la mémoire du réseau	9
4.4 SIM et eSIM	10
4.5 Du réseau à la facture : CDR, médiation, rating, billing.....	10
4.6 Portabilité du numéro	10
5. Architecture typique BSS / OSS d'un opérateur	12
5.1 BSS vs OSS.....	12
5.2 Cartographie fonctionnelle d'un BSS moderne	12
5.3 Correspondance avec les contextes bornés CanTelcoX	12
5.4 Patrons d'architecture courants en BSS	13
6. Identité, authentification et activation	14
6.1 Vérification d'identité (KYC) et de crédit.....	14
6.2 Authentification et MFA.....	14
6.3 Cycle de vie d'une ligne mobile	14
7. Fraudes en télécommunications et mécanismes de défense	16
7.1 Panorama des fraudes courantes.....	16
7.2 Anatomie d'un SIM swap	16
7.3 Contrôles anti-fraude pour CanTelcoX	17
Prévention	17
Détection	17

Réaction.....	17
7.4 Le Wireless Code et les obligations spécifiques SIM swap au Canada	18
7.5 Implications architecturales	18
8. Standards d'intégration : TM Forum Open APIs.....	19
8.1 Pourquoi le TM Forum.....	19
8.2 APIs clés pour le projet.....	19
8.3 Standards GSMA pour eSIM et roaming.....	19
9. Implications pour l'architecture CanTelcoX	21
9.1 Découpage en contextes bornés : pistes de modélisation	21
9.2 Choix microservices vs event-driven	21
9.3 Idempotence, exactly-once, journalisation	21
9.4 Performance et observabilité	22
9.5 Sécurité et vie privée : principes à inscrire dans le dossier	22
10. Glossaire	23
11. Références et ressources pour aller plus loin.....	27
11.1 Cadre réglementaire canadien	27
11.2 Standards d'intégration et architecture	27
11.3 Sécurité, authentification et anti-fraude.....	27
11.4 Observabilité, fiabilité et patrons distribués	27
11.5 Lectures recommandées	27
12. Synthèse et premières pistes pour le dossier d'architecture	29

1. Introduction et objectifs du dossier

Ce dossier rassemble les notions de base, le vocabulaire métier et les repères techniques nécessaires pour aborder l'architecture du système CanTelcoX sans prérequis poussé en télécommunications. Il s'adresse à un architecte logiciel qui maîtrise les patrons de conception, les architectures distribuées et la modélisation du domaine, mais qui n'a pas d'expérience directe du secteur des opérateurs mobiles.

L'objectif n'est pas de produire une encyclopédie des télécoms, mais de couvrir, dans la juste mesure, les concepts qui apparaissent dans le cahier des charges — BSS, HLR/HSS, MSISDN, CDR, portabilité, médiation, valorisation, SIM swap, conformité CRTC et Loi 25 — afin que les choix d'architecture, le découpage en contextes bornés et la justification des attributs de qualité reposent sur une compréhension correcte du domaine.

1.1 Comment lire ce dossier

Le document est organisé en couches : un panorama du secteur canadien, un cadre réglementaire, une description de la chaîne technique d'un opérateur (du réseau à la facturation), puis les sous-domaines où vit la plateforme commerciale (BSS), avant de traiter spécifiquement la fraude et les standards d'intégration. Un glossaire et une bibliographie ferment le document.

Les sections marquées « Implications pour CanTelcoX » traduisent chaque thème en considérations d'architecture concrètes : choix de découpage, attributs de qualité affectés, risques à modéliser. C'est la passerelle entre l'apprentissage du domaine et le travail d'architecture.

1.2 Rappel du périmètre CanTelcoX

Le cahier des charges définit CanTelcoX comme une plateforme BSS (Business Support System) destinée aux abonnés d'un opérateur mobile canadien fictif. Elle couvre le cycle de vie complet d'une ligne mobile côté client : inscription et vérification d'identité, authentification, activation, consultation d'usage, souscription à des forfaits, paiement de factures, détection de fraude et cycle de facturation mensuel.

Les couches réseau (HLR/HSS, équipements radio), la médiation d'usage et le hub de portabilité sont « simulés ». Cela ne dispense pas l'architecte d'en comprendre les contrats et les comportements, car la plateforme commerciale doit dialoguer avec eux selon des règles strictes (idempotence, exactly-once en écriture de facturation, journaux append-only, contrôles anti-fraude).

2. Le secteur des télécommunications mobiles au Canada

2.1 Structure du marché

Le marché mobile canadien est dominé par trois grands opérateurs intégrés, communément appelés les « Big Three » : Rogers Communications, BCE (Bell) et TELUS. Ces groupes contrôlent l'essentiel du réseau, des fréquences attribuées par Innovation, Sciences et Développement économique Canada (ISDE) et des grandes plateformes commerciales.

À côté d'eux, plusieurs opérateurs régionaux et marques secondaires structurent une concurrence à plusieurs vitesses : Vidéotron / Freedom Mobile (Québecor), SaskTel en Saskatchewan, Eastlink dans l'Atlantique, ainsi que les marques discount appartenant aux grands groupes (Fido, Koodo, Virgin Plus, Chatr, Lucky Mobile, Public Mobile). Depuis 2023, le CRTC encadre aussi l'accès des MVNO (Mobile Virtual Network Operators) au réseau des opérateurs principaux.

Pour CanTelcoX, retenir surtout que la concurrence se joue sur le forfait (voix, SMS, données), les options d'itinérance, la qualité de service perçue et l'expérience self-service — ce qui définit largement les exigences fonctionnelles d'un BSS moderne.

2.2 Types d'opérateurs

- **MNO (Mobile Network Operator)** : opérateur possédant son propre réseau radio et cœur de réseau — antennes, stations de base, HLR/HSS, IMS, passerelles SS7/Diameter. Les Big Three sont des MNO.
- **MVNO (Mobile Virtual Network Operator)** : opérateur sans réseau radio propre. Il loue l'accès à un MNO hôte et gère lui-même son BSS, sa marque, ses tarifs et parfois son OCS. Public Mobile, Lucky Mobile, Chatr sont à mi-chemin entre MVNO et sous-marques.
- **Full MVNO vs Light MVNO** : le full MVNO détient son propre HLR/HSS et émet ses propres SIM, le light MVNO délègue tout au MNO hôte et n'opère que la couche commerciale.
- **MVNE / MVNA** : Mobile Virtual Network Enabler / Aggregator — prestataires techniques qui fournissent l'infrastructure BSS aux MVNO sans qu'ils aient à la développer. Modèle pertinent pour positionner CanTelcoX comme une plateforme réutilisable.

2.3 Modèles commerciaux : prépayé vs postpayé

Deux modèles de facturation cohabitent dans tous les BSS modernes :

- **Prépayé (prepaid)** : l'abonné achète du crédit ou un forfait d'avance. L'usage est décompté en temps réel par un Online Charging System (OCS). L'autorisation de chaque appel ou session data est conditionnée à un solde disponible. La latence et la disponibilité de l'OCS sont critiques.

- **Postpayé (postpaid) :** l'abonné consomme d'abord, paie ensuite. L'usage est collecté par CDR, valorisé mensuellement (rating) et facturé (billing). C'est le mode prédominant pour les contrats départis avec engagement ou financement d'appareil.

CanTelcoX doit gérer les deux modèles, ce qui implique que le contexte borné « Lignes & Services » porte le statut tarifaire et que « Usage, Rating & Facturation » traite distinctement charging temps réel et cycle mensuel.

3. Cadre réglementaire canadien

3.1 CRTC et la Loi sur les télécommunications

Le CRTC (Conseil de la radiodiffusion et des télécommunications canadiennes) est l'autorité administrative indépendante qui régule l'industrie. Il agit en vertu de la Loi sur les télécommunications, qui pose les principes de service abordable, accessible et de qualité raisonnable. Pour un BSS comme CanTelcoX, plusieurs décisions et codes du CRTC ont un impact direct :

- **Code sur les services sans fil (Wireless Code)** : plafonne les frais de résiliation, encadre les contrats, oblige une transparence tarifaire (« bill shock » évité), impose des plafonds de données et d'itinérance avec consentement explicite au-delà.
- **Portabilité obligatoire (Wireless Number Portability)** : depuis 2007, un abonné peut transférer son numéro entre opérateurs. La fenêtre de portabilité est typiquement de 2,5 heures. CanTelcoX doit pouvoir initier et recevoir des portages via un hub simulé.
- **Accès 9-1-1** : toute ligne active doit acheminer le 9-1-1 et fournir la localisation. Même si simulé, le modèle doit établir l'association numéro / adresse de service.
- **Liste nationale des numéros de télécommunication exclus (LNTE)** : encadre les communications commerciales sortantes.

3.2 LPRPDE et Loi 25

Sur la vie privée, deux textes sont incontournables pour un opérateur :

- **LPRPDE (Loi sur la protection des renseignements personnels et les documents électroniques)** : loi fédérale qui régit la collecte, l'utilisation et la communication des renseignements personnels par les entreprises. Elle exige consentement, finalité limitée, exactitude, mesures de sécurité et droits d'accès. Les opérateurs y sont assujettis pour leurs activités commerciales interprovinciales.
- **Loi 25 (Québec)** : loi modernisant les dispositions législatives en matière de protection des renseignements personnels. Effective par paliers depuis 2022-2024, elle introduit notifications d'incident, registre, évaluations des facteurs relatifs à la vie privée (EFVP), droit à la portabilité, droit à l'effacement, sanctions importantes (jusqu'à 4 % du chiffre d'affaires mondial), et obligations spécifiques pour la prise de décision automatisée et le profilage.

Implication directe pour l'architecture : traçabilité (journaux append-only sur toute manipulation de données personnelles), ségrégation des données sensibles, anonymisation/pseudonymisation possible, mécanismes d'export et d'effacement, et notification d'incident rapide (« Confidentialité dès la conception » — privacy by design).

3.3 Autres textes et obligations

- **Loi canadienne anti-pourriel (LCAP / CASL) :** encadre les communications électroniques commerciales, exige consentement, retrait facile, identification de l'expéditeur. Tout SMS marketing depuis CanTelcoX entre dans son champ.
- **Code criminel — fraude et usurpation d'identité (art. 380, 402.2) :** cadre les enquêtes et la coopération avec les forces de l'ordre en cas de SIM swap ou de port-out frauduleux.
- **Normes d'accessibilité (Loi canadienne sur l'accessibilité) :** les interfaces grand public doivent satisfaire des critères WCAG 2.1 AA au minimum.

4. Fonctionnement technique d'un opérateur mobile

4.1 Vue d'ensemble de la chaîne

La chaîne technique d'un opérateur mobile peut se résumer en quatre couches successives qui dialoguent entre elles :

- **Couche réseau (RAN + Core)** : antennes, eNodeB / gNodeB, MME, SGW, PGW, UPF, AMF, SMF. Elle achemine les appels, les SMS et les sessions data. C'est là que vivent les équipements radio.
- **Couche de gestion des abonnés (HLR / HSS / UDM)** : base de données centrale des abonnés authentifiés pour le réseau. C'est la source de vérité pour les autorisations radio.
- **Couche d'activation et d'orchestration (Provisioning / OSS)** : traduit les commandes business (« activer la ligne X avec le forfait Y ») en séquence d'appels aux équipements réseau et aux systèmes d'inventaire.
- **Couche commerciale (BSS)** : catalogue de produits, prise de commande, gestion client, médiation, rating, facturation, paiement, support. C'est ici que CanTelcoX se positionne.

4.2 Du numéro de téléphone au profil d'abonné

Trois identifiants techniques essentiels structurent toute modélisation d'un opérateur :

- **MSISDN (Mobile Station International Subscriber Directory Number)** : le « numéro de téléphone » au format international (+1... au Canada). C'est l'identifiant public d'une ligne.
- **IMSI (International Mobile Subscriber Identity)** : identifiant interne 15 chiffres (MCC + MNC + MSIN) lié à la carte SIM. C'est lui qui sert à authentifier l'abonné auprès du réseau, jamais le MSISDN.
- **ICCID (Integrated Circuit Card ID)** : numéro de série unique de la carte SIM (19-20 chiffres). Sert à tracer le matériel.
- **IMEI (International Mobile Equipment Identity)** : identifiant du terminal lui-même. Utilisé pour les listes de blocage en cas de vol.

Pour CanTelcoX, la modélisation d'une « Ligne mobile » porte au minimum un MSISDN, un état (pending, active, suspended, ported-out, deactivated), un IMSI/ICCID associés (ou un identifiant eSIM), un profil de service (forfait, options) et un abonné propriétaire.

4.3 HLR, HSS, UDM : la mémoire du réseau

Le HLR (Home Location Register) est la base historique 2G/3G qui contient le profil d'abonné réseau, ses droits, et son état de localisation logique. Le HSS (Home Subscriber Server) en est l'équivalent 4G/IMS, et l'UDM (Unified Data Management) celui de la 5G. Dans la pratique, on parle souvent encore de « HLR/HSS » pour désigner la fonction de vérité des abonnés côté réseau.

Activer une ligne signifie créer ou mettre à jour son entrée dans le HSS : lier IMSI, MSISDN, clés d'authentification (Ki/AKA), profil de QoS, droits APN, etc. La plateforme commerciale ne touche jamais ces structures directement : elle délègue au provisioning, qui pilote le HSS via une interface (REST, Diameter, propriétaire) — dans CanTelcoX, cette interface est simulée.

4.4 SIM et eSIM

La carte SIM est un élément sécurisé (smart card) qui contient l'IMSI, les clés cryptographiques et un mini-système d'exploitation. Sa version logicielle, l'eSIM (embedded SIM ou eUICC), permet d'installer à distance un profil opérateur via les normes GSMA SGP.21/22 (consumer) et SGP.31/32 (M2M/IoT).

L'eSIM change profondément le parcours d'activation : pas d'envoi physique, téléchargement d'un profil par QR code ou SM-DP+. Pour CanTelcoX, cela signifie un cas d'usage « activation eSIM » qui doit générer une activation code et orchestrer la délivrance du profil. Cela ouvre aussi un nouveau vecteur de fraude (« eSIM swap »), à traiter de la même manière qu'un SIM swap classique.

4.5 Du réseau à la facture : CDR, médiation, rating, billing

Quand un abonné passe un appel, envoie un SMS ou ouvre une session data, l'équipement réseau (MSC, SMSC, PGW/UPF) génère des enregistrements de type CDR (Call Detail Record) ou UDR (Usage Data Record). Ces fichiers contiennent au minimum : type d'événement, numéro A (appellant), numéro B (appelé), horodatage, durée ou volume, identifiants de cellule, codes de service.

Le traitement se déroule ensuite en plusieurs étapes :

- **Médiation** : collecte multi-source des CDR, normalisation au format pivot, déduplication, filtrage des doublons et des CDR invalides, enrichissement (recherche du contrat correspondant au MSISDN), routage vers les processus aval (rating, fraud, lawful intercept, analytics).
- **Rating** : valorisation monétaire de chaque usage selon le forfait, les options actives, la couverture (national, roaming), les promotions. Produit des EDR (Event Detail Records) tarifés.
- **Charging** : en prépayé, autorisation en temps réel via un OCS (Online Charging System) qui décompte sur les compteurs. En postpayé, accumulation dans des compteurs de cycle.
- **Billing** : en fin de cycle (généralement mensuel), agrégation des EDR, application des frais récurrents et ponctuels, taxes, remises, génération de la facture, archivage, mise à disposition de l'abonné, envoi en collecte.

Le cahier des charges de CanTelcoX nomme explicitement la médiation et la valorisation comme contexte borné « Usage, Rating & Facturation ». Comprendre ce flux est indispensable pour modéliser correctement la propriété des données, les SLA et la transactionnalité (notamment l'exigence « exactly-once pour écritures de facturation »).

4.6 Portabilité du numéro

Au Canada, la portabilité mobile s'appuie sur un hub central de coordination entre opérateurs. Une demande de portage suit généralement ce flux : l'abonné souscrit chez l'opérateur d'accueil, ce dernier soumet une demande PAC (Port Authorization Code, ou équivalent identifiant client) au hub, qui notifie l'opérateur d'origine. Après validation (identité, paiement, absence de litige), une fenêtre de bascule est planifiée. Le routage du numéro est mis à jour dans les bases de routage (NPDB), et la ligne ancienne est désactivée.

Le port-out (sortie) est un point de fraude critique : si l'opérateur d'origine valide mal, un attaquant peut détourner le numéro vers un opérateur tiers. CanTelcoX, en tant qu'opérateur fictif, doit modéliser ces deux directions et les contrôles anti-fraude associés.

5. Architecture typique BSS / OSS d'un opérateur

5.1 BSS vs OSS

La distinction historique BSS / OSS divise les systèmes de gestion d'un opérateur en deux familles :

- **BSS (Business Support Systems)** : « face client et finance » — CRM, catalogue de produits, prise de commande, médiation, rating, facturation, paiement, recouvrement, libre-service.
- **OSS (Operations Support Systems)** : « face réseau et exploitation » — inventaire réseau, provisioning, activation, gestion des incidents (fault management), performance, capacité, qualité de service.

CanTelcoX est explicitement positionné comme un BSS, mais dialogue avec des fonctions OSS simulées — HLR/HSS, hub de portabilité, médiation. L'architecte doit donc définir des frontières propres entre ces deux mondes (anti-corruption layer, adaptateurs, contrats d'événements stables).

5.2 Cartographie fonctionnelle d'un BSS moderne

Un BSS moderne regroupe en général les capacités suivantes, souvent organisées en services autonomes :

- **Customer Management** : identité, comptes, hiérarchies (particulier, foyer, entreprise), préférences, consentements.
- **Product Catalog** : produits, offres commerciales, prix, règles de compatibilité, calendrier (lancement / retrait).
- **Order Management** : panier, prise de commande, orchestration, suivi d'avancement, gestion des échecs et reprises.
- **Service Provisioning** : traduction d'une commande en actions techniques (activation HSS, attribution MSISDN, livraison eSIM).
- **Mediation** : collecte et normalisation des usages réseau.
- **Rating & Charging** : valorisation, OCS pour le prépayé.
- **Billing** : cycle de facturation, taxes, remises, factures, communication client.
- **Payment & Collections** : encaissements, modes de paiement, gestion des impayés.
- **Customer Self-Care** : portail web / app mobile pour consultation et gestion.
- **Revenue Assurance / Fraud Management** : contrôles transversaux sur les pertes de revenus et les comportements suspects.

5.3 Correspondance avec les contextes bornés CanTelcoX

Le cahier des charges identifie six contextes bornés (bounded contexts au sens DDD). Voici comment ils s'alignent sur le modèle BSS canonique :

Contexte CanTelcoX	Capacités BSS couvertes	Standards TMF apparentés
Clients & Identité	Customer Management, KYC, authentification, gestion des rôles et des consentements	TMF629 Customer Management, TMF632 Party Management, TMF669 Policy
Lignes & Services	Service Inventory, MSISDN, SIM/eSIM, statuts de ligne	TMF638 Service Inventory, TMF641 Service Order
Commandes & Activations	Order Management, orchestration vers le provisioning	TMF622 Product Ordering, TMF641 Service Ordering
Catalogue & Offres	Product Catalog, règles d'éligibilité, promotions, prix	TMF620 Product Catalog Management
Usage, Rating & Facturation	Médiation, rating, billing, factures, paiement	TMF635 Usage Management, TMF666 Account, TMF678 Bill, TMF676 Payment
Conformité & Audit	Détection de fraude, journaux immuables, rapports réglementaires	TMF671 Notification, TMF688 Event, TMF701 Performance

5.4 Patrons d'architecture courants en BSS

Quelques patrons reviennent constamment dans la littérature et l'industrie BSS, et méritent d'être évalués pour CanTelcoX :

- **Catalog-driven** : toute offre est modélisée en données dans le catalogue ; aucun chemin de code n'est spécifique à un produit. Prérequis pour faire évoluer le catalogue sans redéploiement.
- **Order orchestration** : une commande passe par une machine à états (sagas, BPMN, workflow) avec compensation. C'est ici que vivent l'idempotence et la gestion des échecs.
- **Event-driven backbone** : les événements « LigneActivée », « CommandeAcceptée », « PaiementReçu » circulent sur un bus durable (Kafka, NATS) et alimentent les domaines aval (facturation, fraude, analytics) en lecture asynchrone.
- **CQRS pour la consultation** : séparation des modèles d'écriture (commandes) et de lecture (consultation d'usage, factures), pour atteindre les cibles de latence P95.
- **Outbox pattern** : publication d'événements dans la même transaction que l'écriture métier pour garantir l'at-least-once, complété par une déduplication consommateur pour l'exactly-once logique.
- **Anti-corruption layer** : autour de chaque système externe simulé (HSS, médiation, portabilité), pour isoler le modèle interne.

6. Identité, authentification et activation

6.1 Vérification d'identité (KYC) et de crédit

Au Canada, l'activation d'une ligne mobile postpayée implique une vérification d'identité et souvent un contrôle de crédit. Les opérateurs combinent généralement : validation d'une pièce d'identité gouvernementale, comparaison avec une base de fraude interne, vérification d'adresse, et requête aux bureaux de crédit (Equifax, TransUnion) pour le postpayé. En prépayé, le KYC est plus léger mais l'enregistrement reste obligatoire (lutte contre l'anonymat).

Pour CanTelcoX, la pièce d'identité est « simulée », mais le contexte « Clients & Identité » doit modéliser explicitement :

- un statut d'identité (non vérifié, en cours, vérifié, refusé) ;
- un score ou une cote de risque (sortie d'un service simulé de scoring) ;
- un journal des vérifications avec horodatage, source et résultat ;
- des données sensibles séparées (chiffrées au repos, accès restreint).

6.2 Authentification et MFA

L'authentification côté espace client repose généralement sur des facteurs combinés : identifiant + mot de passe, plus un deuxième facteur (OTP par SMS ou e-mail, application TOTP, WebAuthn / passkey, biométrie sur l'appareil). Le cahier des charges mentionne « OTP / WebAuthn » dans UC-02, ce qui invite à raisonner en termes de niveau d'assurance plutôt qu'à imposer un facteur unique.

Un point délicat : le SMS comme deuxième facteur est précisément la cible des attaques SIM swap. Une architecture moderne prévoit donc des facteurs alternatifs (TOTP, passkeys WebAuthn / FIDO2) et réserve le SMS aux opérations à faible risque ou en facteur complémentaire. Pour les actions sensibles (port-out, changement d'adresse, changement de mot de passe), un facteur « possession » non-SMS doit être exigé.

Références utiles : NIST SP 800-63B (digital identity guidelines), CST (Communications Security Establishment) ITSP.30.031 (lignes directrices canadiennes sur l'authentification).

6.3 Cycle de vie d'une ligne mobile

Pour CanTelcoX, une modélisation propre du statut d'une ligne pourrait s'appuyer sur les états suivants, avec transitions auditable :

- **Pending** : commande prise, en attente d'activation réseau.
- **Active** : ligne provisionnée, usage possible.
- **Suspended (involontaire)** : suspension pour impayé, fraude, demande réglementaire.
- **On hold (volontaire)** : suspension temporaire à la demande de l'abonné (« vacation hold »).

- **Ported-out** : numéro transféré chez un autre opérateur.
- **Deactivated** : résiliation, le numéro entre en quarantaine avant réaffectation.

Les transitions doivent être journalisées de manière append-only (exigence du cahier des charges) pour satisfaire la traçabilité CRTC et l'audit Loi 25.

7. Fraudes en télécommunications et mécanismes de défense

7.1 Panorama des fraudes courantes

La fraude télécom pèse chaque année plusieurs dizaines de milliards de dollars dans le monde (estimations CFCA — Communications Fraud Control Association). Les principales familles à modéliser pour CanTelcoX sont :

- **SIM swap (échange de SIM frauduleux)** : un attaquant convainc l'opérateur de transférer le numéro d'une victime sur une SIM qu'il contrôle. Une fois le numéro intercepté, il bypassé les MFA SMS et accède aux comptes bancaires, courriels et portefeuilles crypto. C'est le risque le plus visible médiatiquement.
- **Port-out fraud** : variante du SIM swap où l'attaquant fait porter le numéro chez un autre opérateur. Mêmes mécanismes de prévention.
- **Subscription fraud** : souscription sous fausse identité (ou identité volée), avec intention de ne pas payer ou d'écouler des appels surtaxés.
- **IRSF (International Revenue Share Fraud)** : appels passez sur des numéros internationaux surtaxés contrôlés par les fraudeurs, qui touchent une part du revenu d'interconnexion.
- **Wangiri (« one-ring »)** : appels en absence qui incitent au rappel d'un numéro surtaxé.
- **Roaming fraud** : exploitation du décalage temporel entre la consommation en roaming et sa remontée par l'opérateur visité (TAP files), pour accumuler des charges avant blocage.
- **Bypass / SIM box** : terminaison frauduleuse d'appels internationaux par des bancs de SIM pour éviter les frais d'interconnexion.
- **Account takeover (ATO)** : prise de contrôle du compte client (espace abonné), pas nécessairement de la ligne. Sert souvent de prélude au SIM swap.

7.2 Anatomie d'un SIM swap

Un scénario typique de SIM swap se déroule en plusieurs étapes :

- **1. Reconnaissance** : l'attaquant collecte des données personnelles sur la victime (fuites publiques, ingénierie sociale, hameçonnage).
- **2. Approche de l'opérateur** : par téléphone, en boutique, via le libre-service. L'attaquant prétend avoir perdu son téléphone et demande l'activation d'une nouvelle SIM.
- **3. Bypass des contrôles** : par usurpation d'identité, complicité interne, ou exploitation de procédures faibles.
- **4. Activation de la SIM attaquante** : l'IMSI de la nouvelle SIM est associé au MSISDN. L'ancienne SIM perd le service.
- **5. Interception des OTP** : connexion aux services protectes par SMS-OTP — banque, e-mail, crypto. Vidage des comptes.

- **6. Effacement des traces** : changement de mots de passe, suppression d’alertes.

La fenêtre critique est typiquement de quelques heures à quelques jours. Le système doit donc détecter, alerter et bloquer rapidement.

7.3 Contrôles anti-fraude pour CanTelcoX

La conception d’un dispositif anti-fraude se décline sur trois axes : prévention, détection, réaction.

Prévention

- Authentification renforcée pour toute opération sensible (changement de SIM, port-out, changement de mot de passe, changement d’adresse). Préférer WebAuthn / passkeys au SMS-OTP.
- Période de « cooling-off » obligatoire entre une opération sensible et son exécution effective (par exemple 24-72 h pour un SIM swap).
- Notifications immédiates par canal hors-bande (e-mail, app push) à chaque opération sensible, avec lien de contestation en un clic.
- Verrou de port-out (port freeze) que l’abonné peut activer pour bloquer toute demande de portage sans une seconde validation explicite.
- Limitation des canaux : certaines opérations ne sont accessibles qu’après vidéo-identification ou en boutique.

Détection

- Règles déterministes : changement de SIM moins de N heures après changement de mot de passe, changement d’appareil + changement de SIM + nouveau pays en moins de 24 h, etc.
- Scoring de risque par modèles : features sur le profil (ancienneté, historique d’incidents), l’appareil (IMEI nouveau), la localisation (géo-IP, cellule radio), le comportement (heure inhabituelle), et l’identité (vitesse de vérification, sources de données).
- Analyse des CDR : pics inhabituels d’appels internationaux vers des destinations à risque IRSF, ratios appels/SMS anormaux, sessions data simultanées dans des géographies incompatibles (« velocity check »).
- Corrélation cross-domaine : combinaison événements d’identité, commande, usage, paiement. C’est là que l’architecture event-driven est précieuse.

Réaction

- Mise en quarantaine automatique de l’opération suspecte (la SIM activée ne reçoit le service qu’après validation).
- Notification multicanal à l’abonné et au service fraude.
- Création automatique d’un dossier de fraude tracé (journal append-only), avec workflow d’enquête.

- Coopération réglementaire (CRTC, forces de l'ordre) à partir d'éléments preuve immuables.

7.4 Le Wireless Code et les obligations spécifiques SIM swap au Canada

Le CRTC a, ces dernières années, accentué la pression réglementaire sur les opérateurs pour qu'ils mettent en place des contrôles anti-SIM-swap renforcés. La décision CRTC 2024-291 (Wireless Code review) et les engagements de l'industrie convergent vers des exigences de notification immédiate, période de gel par défaut, alternative à l'OTP SMS et traçabilité complète. Même si le projet est académique, modéliser ces obligations donne une assise réaliste aux exigences non fonctionnelles « Conformité & Audit ».

7.5 Implications architecturales

- **Bus d'événements transversal** : chaque action sensible émet un événement qui alimente le moteur de fraude. La détection est asynchrone, ce qui justifie l'architecture event-driven.
- **Journal append-only** : un store « fraude/audit » dédié, en mode WORM (write-once, read-many), couvre les exigences CRTC et Loi 25.
- **Throttling et circuit breakers** : toute opération sensible passe par un orchestrateur qui peut couper les flux entrants si une vague suspecte est détectée.
- **Séparation des autorisations** : une opération « swap SIM » nécessite deux événements indépendants (validation par l'abonné + délai), modélisé en saga.
- **Données minimales** : le moteur de fraude ne doit pas recevoir plus de données personnelles que nécessaire (principe Loi 25).

8. Standards d'intégration : TM Forum Open APIs

8.1 Pourquoi le TM Forum

Le TM Forum est l'association industrielle de référence pour les standards d'intégration en télécoms. Ses Open APIs décrivent des contrats REST (ressources, opérations, schémas JSON) pour chaque fonction BSS/OSS. Les grands opérateurs mondiaux les adoptent comme base d'interopérabilité. Le cahier des charges les cite « à titre de référence industrielle et sans obligation ».

Pour CanTelcoX, l'intérêt n'est pas tant d'implémenter à la lettre que de structurer le modèle de domaine et les contrats d'API en s'inspirant de standards éprouvés. Cela rend le projet plus crédible et facilite des extensions futures.

8.2 APIs clés pour le projet

API	Nom	Usage dans CanTelcoX
TMF620	Product Catalog Management	Modèle du catalogue d'offres, des produits, des prix et des règles de compatibilité. Base du contexte « Catalogue & Offres ».
TMF622	Product Ordering	Cycle de vie de la commande de produits. Cadre du contexte « Commandes & Activations ».
TMF629	Customer Management	Modélisation des clients, comptes, contacts. Complète le contexte « Clients & Identité ».
TMF666	Account Management	Comptes de facturation, balances, structure financière. Pilier du contexte « Usage, Rating & Facturation ».
TMF635	Usage Management	Collecte et exposition des usages (CDR/EDR). Utile pour la consultation d'usage en self-service.
TMF678	Customer Bill Management	Cycle de facturation, factures, lignes de facture.
TMF676	Payment Management	Encaissements et règlements.
TMF641	Service Ordering	Couche service entre commande produit et provisioning réseau.
TMF688	Event Management	Format normalisé d'événements inter-domaines, pertinent pour le backbone event-driven.

8.3 Standards GSMA pour eSIM et roaming

Pour les aspects matériels et réseau (même simulés), la GSMA fournit les normes de référence : SGP.21 et SGP.22 (eSIM consumer), SGP.31/32 (IoT), BA.27 (Wholesale Roaming), TAP/RAEX (échanges inter-

opérateurs). Ces standards dépassent CanTelcoX, mais connaître leur nom permet de positionner correctement les frontières des systèmes simulés.

9. Implications pour l'architecture CanTelcoX

9.1 Découpage en contextes bornés : pistes de modélisation

Le découpage proposé par le cahier des charges (Clients & Identité, Lignes & Services, Commandes & Activations, Catalogue & Offres, Usage / Rating / Facturation, Conformité & Audit) est solide et aligné avec la pratique de l'industrie. Quelques précisions méritent d'être formulées tôt dans l'architecture :

- **Distinguer « identité » et « client »** : l'identité numérique (login, MFA, sessions) est un sous-domaine technique, alors que le client (party, comptes, consentements) est métier. Les mêtrer dans le même contexte est tentant mais crée du couplage. Une scission « Identity Provider » / « Customer » mérite d'être évaluée.
- **Catalogue immuable** : le catalogue produit doit être versionné. Une commande référence une version spécifique des produits, sinon les vérifications a posteriori (audit, contestation) deviennent impossibles.
- **Conformité & Audit comme contexte horizontal** : plutôt qu'un service en bout de chaîne, c'est une capacité transversale alimentée par les événements des autres contextes. Le bus d'événements est donc structurant.

9.2 Choix microservices vs event-driven

Le cahier des charges propose deux architectures candidates avec des SLA décroissants pour l'option microservices et plus exigeants pour l'option event-driven (latence P95 ≤ 250 ms, débit ≥ 1000 op/s, disponibilité 99 %). La nuance à documenter dans le dossier d'architecture :

- **Microservices synchrones** : plus simples à raisonner, latence par appel prévisible, dette d'orchestration limitée à quelques services. Pertinents pour les opérations interactives (consultation, login). En revanche, les sagas longues (activation, portabilité) deviennent difficiles à gérer en pur synchrone.
- **Event-driven** : découple temporellement, monte mieux en charge, facilite la résilience et la conformité (journal d'événements naturel). Latence perçue par le client peut rester basse via patterns CQRS. Coûts : complexité opérationnelle (bus durable, gestion de l'ordre, garanties de livraison, évolution des schémas).

La voie raisonnable est souvent hybride : synchrone pour les requêtes clientes de lecture, asynchrone pour les workflows d'écriture longue. Le dossier d'architecture doit justifier ce choix au regard des exigences chiffrées.

9.3 Idempotence, exactly-once, journalisation

- **Idempotence** : chaque commande externe (HTTP POST de création d'ordre, activation) doit accepter une clé idempotente fournie par l'appelant. Même requête répétée produit la même réponse, sans effet secondaire dupliqué.

- **Exactly-once de facturation** : chaque CDR ne doit être facturé qu'une fois. Mise en œuvre courante : at-least-once en transport + déduplication par clé unique en consommation, ou outbox / inbox pattern.
- **Append-only audit log** : un store technique (par exemple S3 + Object Lock, ou bases spécialisées) qui reçoit chaque événement « significatif » avec sceau temporel.

9.4 Performance et observabilité

Les cibles « 4 Golden Signals » (latence, trafic, erreurs, saturation) issues du SRE Book de Google sont le point de départ. Les compléter avec : traces distribuées (OpenTelemetry), logs structurés (JSON, correlation id), métriques business (taux d'activation, taux d'échec, latence du cycle de facturation), tableaux de bord par contexte.

9.5 Sécurité et vie privée : principes à inscrire dans le dossier

- **Zero trust** : chaque appel inter-services authentifié (mTLS / JWT court), autorisation portée par l'appelant (claims), pas de confiance implicite par réseau.
- **Privacy by design** : minimisation, chiffrement au repos, key rotation, masking des champs sensibles dans les logs, droits d'accès par rôle.
- **Traçabilité des consentements** : chaque consentement marketing, profil, et donnée secondaire est associé à un événement de consentement immuable.
- **Cycle de gestion des incidents** : processus défini pour notification CRTC / Commissariat à la vie privée dans les délais légaux.

10. Glossaire

Le glossaire ci-dessous reprend les sigles et termes utilisés dans le cahier des charges et dans le présent dossier. Il est ordonné alphabétiquement pour faciliter la consultation.

Terme	Définition
5G	Cinquième génération de réseau mobile, introduisant le slicing, l'architecture cloud-native du cœur et des latences faibles.
AMF	Access and Mobility Management Function — fonction du cœur 5G gérant l'enregistrement et la mobilité.
APN	Access Point Name — nom du point d'accès data côté réseau.
BSS	Business Support System — ensemble des systèmes « face client et finance » d'un opérateur. CanTelcoX est un BSS.
CDR	Call Detail Record — enregistrement d'un événement d'usage réseau (appel, SMS, session data). Base de la médiation et de la facturation.
CFCA	Communications Fraud Control Association — association industrielle de référence sur les fraudes télécoms.
CRTC	Conseil de la radiodiffusion et des télécommunications canadiennes — régulateur fédéral.
CST	Centre de la sécurité des télécommunications — organisme fédéral de sécurité des communications.
EDR	Event Detail Record — CDR enrichi et valorisé par le rating, prêt à être facturé.
eSIM / eUICC	Carte SIM intégrée (embedded UICC) permettant de télécharger un profil opérateur à distance via les normes GSMA SGP.21/22.
Event-driven	Style d'architecture où les composants communiquent par événements asynchrones publiés sur un bus durable.
Exactly-once	Garantie qu'un message ou une opération produit son effet une et une seule fois, même en cas de retransmission.
FIDO2 / WebAuthn	Standards d'authentification forte par clés asymétriques stockées sur l'appareil ou clé matérielle. Alternative au SMS-OTP.
Forfait	Offre commerciale combinant voix, SMS et données à prix forfaitaire (avec ou sans engagement).
GSMA	GSM Association — organisation mondiale des opérateurs mobiles. Source des standards eSIM, roaming, etc.
HLR	Home Location Register — base 2G/3G stockant le profil réseau de l'abonné.

Terme	Définition
HSS	Home Subscriber Server — équivalent 4G/IMS du HLR.
ICCID	Integrated Circuit Card Identifier — numéro de série unique de la carte SIM.
Idempotence	Propriété d’une opération qui produit le même résultat qu’elle soit exécutée une ou plusieurs fois.
IMEI	International Mobile Equipment Identity — identifiant unique du terminal mobile.
IMS	IP Multimedia Subsystem — cœur de réseau pour la voix sur IP (VoLTE, VoNR).
IMSI	International Mobile Subscriber Identity — identifiant interne de l’abonné sur le réseau, porté par la SIM.
IRSF	International Revenue Share Fraud — fraude exploitant les numéros internationaux à revenu partagé.
ISDE	Innovation, Sciences et Développement économique Canada — ministère gérant l’attribution des fréquences.
KYC	Know Your Customer — ensemble des procédures de vérification de l’identité du client.
LCAP / CASL	Loi canadienne anti-pourriel.
LNTE	Liste nationale des numéros de télécommunication exclus.
Loi 25	Loi québécoise sur la protection des renseignements personnels, en vigueur par paliers depuis 2022.
LPRPDE	Loi sur la protection des renseignements personnels et les documents électroniques (fédérale).
MFA	Multi-Factor Authentication — authentification à plusieurs facteurs (connaissance, possession, inhérence).
Mediation	Couche de collecte et de normalisation des usages réseau (CDR) avant rating.
MNO	Mobile Network Operator — opérateur possédant son propre réseau.
MSC	Mobile Switching Center — cœur de commutation pour la voix circuit (2G/3G).
MSISDN	Mobile Station International Subscriber Directory Number — numéro de téléphone international.
MVNO	Mobile Virtual Network Operator — opérateur virtuel sans réseau radio propre.

Terme	Définition
MVNE / MVNA	Mobile Virtual Network Enabler / Aggregator — fournisseur BSS pour MVNOs.
NPDB	Number Portability Data Base — base centrale de routage des numéros portés.
OCS	Online Charging System — système de tarification temps réel pour le prépayé.
OSS	Operations Support System — systèmes « face réseau » (provisioning, inventaire, supervision).
OTP	One-Time Password — code à usage unique pour MFA.
Outbox pattern	Patron qui publie les événements dans la même transaction que l'écriture métier, pour garantir l'at-least-once.
PGW / UPF	Packet Data Network Gateway (4G) / User Plane Function (5G) — passerelles data du cœur de réseau.
Portabilité	Capacité réglementaire pour un abonné de conserver son numéro en changeant d'opérateur.
Port freeze	Verrou de portabilité activé par l'abonné pour bloquer toute demande de portage non validée explicitement.
Postpayé	Modèle commercial où l'abonné paye sur facture après consommation.
Prépayé	Modèle commercial où l'abonné achète du crédit avant consommation.
Provisioning	Action d'appliquer les configurations nécessaires sur les équipements réseau pour activer un service.
RAN	Radio Access Network — partie radio du réseau mobile (antennes, eNodeB, gNodeB).
Rating	Valorisation monétaire d'un usage en appliquant les tarifs du forfait et des options.
Roaming	Itinérance — utilisation du réseau d'un opérateur partenaire à l'étranger.
SIM	Subscriber Identity Module — carte à puce contenant l'IMSI et les clés cryptographiques.
SIM swap	Fraude consistant à transférer un numéro vers une SIM contrôlée par l'attaquant.
SMSC	Short Message Service Center — centre de service SMS du cœur de réseau.
TAP	Transferred Account Procedure — fichier d'échange de données de roaming entre opérateurs.

Terme	Définition
TMF / TM Forum	Association industrielle qui publie les Open APIs et le framework eTOM.
TOTP	Time-based One-Time Password — OTP généré par application (RFC 6238).
UDM	5G Unified Data Management — équivalent moderne du HSS.
UDR	Usage Data Record — généralisation du CDR pour les usages data.
Wangiri	Fraude « one-ring » : appels en absence pour provoquer un rappel vers un numéro surtaxé.
WebAuthn	Standard W3C d'authentification à clé publique, base des passkeys.
Wireless Code	Code du CRTC sur les services sans fil aux particuliers et PME.
WNP	Wireless Number Portability — portabilité obligatoire au Canada depuis 2007.

11. Références et ressources pour aller plus loin

11.1 Cadre réglementaire canadien

- CRTC — Code sur les services sans fil : crtc.gc.ca/fra/phone/mobile/code.htm
- CRTC — Portabilité des numéros : crtc.gc.ca/fra/phone/mobile/portab.htm
- LPRPDE (Commissariat à la protection de la vie privée du Canada) : priv.gc.ca — LPRPDE
- Loi 25 (Commission d'accès à l'information du Québec) : cai.gouv.qc.ca
- LCAP / CASL : crtc.gc.ca/fra/internet/anti.htm

11.2 Standards d'intégration et architecture

- TM Forum Open APIs : tmforum.org/open-apis
- eTOM (Business Process Framework) : tmforum.org/business-process-framework
- GSMA — eSIM consumer (SGP.21/22) : gsma.com/esim
- Microservices.io (Chris Richardson) : microservices.io/patterns
- Domain-Driven Design Reference (Eric Evans) : domainlanguage.com/ddd/reference

11.3 Sécurité, authentification et anti-fraude

- NIST SP 800-63B (Digital Identity Guidelines) : pages.nist.gov/800-63-3/sp800-63b.html
- FIDO Alliance / WebAuthn : fidoalliance.org/passkeys
- CFCA — Communications Fraud Control Association : cfca.org
- FCC / Industry Guidance on SIM Swap (transposable au Canada) : fcc.gov — [SIM swap fraud](#)

11.4 Observabilité, fiabilité et patrons distribués

- Google SRE Book : sre.google/sre-book
- OpenTelemetry : opentelemetry.io
- Saga / Outbox patterns : microservices.io — [Saga](#)

11.5 Lectures recommandées

- Eric Evans,
- *Domain-Driven Design : Tackling Complexity in the Heart of Software* — référence pour les contextes bornés.
- *Building Microservices* — Sam Newman — pour la décomposition et les compromis de l'architecture distribuée.

- *Designing Data-Intensive Applications* — Martin Kleppmann — pour les garanties (consistency, exactly-once, event log) qui sous-tendent un BSS robuste.
- *TM Forum Frameworx (eTOM / SID / TAM)* — pour comprendre la cartographie métier de référence d'un opérateur.

12. Synthèse et premières pistes pour le dossier d'architecture

En ramassant les fils du dossier, quelques convictions émergent qui peuvent guider la prochaine phase du projet :

- **Un BSS bien découpé vit ou meurt par son catalogue et son order management.** Investir tôt dans la modélisation du catalogue (versionné, immuable) paye pour toutes les fonctionnalités aval.
- **La conformité n'est pas un module isolé ;** elle est nourrie par un journal d'événements append-only que tous les contextes alimentent.
- **Le SIM swap est l'histoire emblématique du domaine ;** le traiter correctement (cooling-off, notifications, MFA non-SMS, port freeze) sert d'étude de cas à toute la démarche anti-fraude.
- **Les choix microservices vs event-driven sont à justifier sur des scénarios précis (UCs)** plutôt qu'en abstrait. Le dossier d'architecture y gagnera en crédibilité.
- **S'inspirer des TMF Open APIs** donne une critères de qualité implicite : si le modèle interne et les contrats peuvent se projeter sur TMF620/622/629/666, l'architecture est probablement saine.

Comme prochaine étape, l'idéal est de produire un context map DDD initial mettant en relation les six contextes bornés, en précisant pour chaque couple le type de relation (partenariat, conformiste, anti-corruption layer), et un diagramme de séquence pour les deux cas d'usage les plus structurants : UC-03 « Activation d'une ligne mobile » (qui touche presque tous les contextes) et UC-07 « Détection de fraude » (qui valide la nature transversale du contexte Conformité & Audit).

Ce dossier vous donne le langage commun pour discuter avec un équipier qui connaît les télécoms, et la matière pour justifier vos décisions d'architecture devant un correcteur.